

ABC Healthcare Services

ACCEPTABLE USE POLICY

Information Security Governance Program

Field	Details
Document ID	AUP-001
Version	1.0
Classification	Internal
Policy Owner	Information Security Manager
Approved By	Executive Management
Effective Date	June 1, 2026
Review Date	June 1, 2027

1. PURPOSE

The purpose of this Acceptable Use Policy (AUP) is to establish rules and responsibilities governing the use of ABC Healthcare Services' information systems, devices, applications, networks, and data assets. This policy aims to protect organizational information, reduce cybersecurity risks, support regulatory compliance requirements, and maintain the confidentiality, integrity, and availability of company resources. Failure to comply with this policy may expose the organization to security breaches, financial loss, regulatory penalties, and reputational damage.

2. SCOPE

The Acceptable Use Policy applies to all individuals who access, use, manage, or support ABC Healthcare Services' information systems and technology resources. This includes full-time and part-time employees, contractors, consultants, vendors, third-party service providers, and temporary staff. The policy also applies to all organizational technology assets and information resources, including company-issued laptops, desktop computers, servers, mobile devices, cloud-based applications, email systems, collaboration platforms, corporate networks, internet services, and any other systems used to store, process, or transmit organizational information. All users are expected to comply with the requirements of this policy when accessing or using company resources, regardless of their location or employment status.

3. POLICY OBJECTIVES

The objectives of this policy are:

- Protect organizational information assets.
- Ensure responsible use of corporate technology.
- Minimize insider threats and unauthorized activities.
- Reduce malware and ransomware risks.
- Support ISO 27001 security controls.
- Promote cybersecurity awareness.

4. ACCEPTABLE USE REQUIREMENTS

4.1 Authorized Business Use

Corporate systems shall primarily be used for authorized business purposes.

Users are permitted to:

- Access business applications.
- Use approved software.
- Access approved cloud platforms.
- Communicate using corporate email.
- Use collaboration tools such as Microsoft Teams.
- Access organizational files necessary for job duties.

4.2 Internet Usage

Users may access the internet for legitimate business purposes and limited personal use provided such use:

- Does not interfere with productivity.
- Does not violate company policies.
- Does not consume excessive bandwidth.

4.3 Email Usage

Corporate email systems shall only be used for authorized communications.

Users shall:

- Verify recipients before sending emails.
- Report phishing attempts.
- Avoid transmitting sensitive information through unauthorized channels.
- Use approved encryption methods when required.

5. PROHIBITED ACTIVITIES

- Share passwords.
- Install unauthorized software.
- Disable antivirus protection.
- Circumvent security controls.
- Download pirated material.
- Access illegal or offensive content.
- Connect unauthorized devices.
- Use company resources for personal business.
- Attempt to gain unauthorized system access.
- Store corporate data on personal cloud platforms.
- Introduce malware or unapproved applications.

6. DATA HANDLING REQUIREMENTS

All users must handle information according to the organization's Data Classification Policy. Requirements include:

- Sensitive data must be encrypted.
- Confidential information must not be shared externally without authorization.
- Data shall only be stored in approved locations.
- Information shall be securely disposed of when no longer required.

7. REMOTE ACCESS REQUIREMENTS

Employees working remotely must:

- Use company-approved VPN solutions.
- Enable Multi-Factor Authentication (MFA).
- Use company-managed devices whenever possible.
- Maintain up-to-date antivirus software.
- Report security incidents immediately.

8. USER RESPONSIBILITIES

Employees

- Follow all security policies.
- Protect credentials.
- Report suspicious activities.
- Complete required security training.

Managers

- Ensure employee compliance.
- Support security awareness initiatives.
- Escalate violations when identified.

Information Security Team

- Monitor policy compliance.
- Investigate security violations.
- Perform periodic reviews.

9. SECURITY AWARENESS REQUIREMENTS

All personnel must complete annual cybersecurity awareness training.

Training topics include:

- Phishing awareness
- Password security
- Social engineering
- Data protection
- Incident reporting

10. COMPLIANCE MONITORING

Key Performance Indicators (KPIs)

Metric	Target
Security Training Completion	100%
Policy Acknowledgements	100%
MFA Adoption	100%
Phishing Reporting Rate	>90%
Access Review Completion	100%

Example Compliance Results

Control	Current Status
Security Training	98%
MFA Adoption	100%
Policy Acknowledgement	97%
Access Reviews	100%

11. POLICY VIOLATIONS

Policy violations may result in:

- Verbal warning
- Written warning
- Suspension of privileges
- Employment termination
- Legal action where appropriate

All violations shall be investigated by the Information Security Team.

12. POLICY EXCEPTIONS

Requests for policy exceptions must include:

- Business justification
- Risk assessment
- Compensating controls
- Management approval
- Security approval

Exceptions shall be reviewed annually.

13. REFERENCES

- ISO/IEC 27001:2022
- NIST Cybersecurity Framework
- CIS Critical Security Controls
- Information Security Governance Framework
- Data Classification Policy

14. Compliance Mapping Table

Policy Section	ISO 27001 Area
Acceptable Use	A.5
Access Requirements	A.8
User Responsibilities	A.6
Monitoring	A.5
Exceptions	A.5

15.DOCUMENT CONTROL

Field	Value
Document Owner	Information Security Manager
Version	1.0
Classification	Internal
Review Frequency	Annually
Next Review Date	October 1, 2027